

INFORME PROFESIONAL DE PENTESTING WORDPRESS - INLANEFREIGHT

Fecha: Mayo 2026

Autor: Equipo de Seguridad Ofensiva

Cliente: INLANEFREIGHT

Objetivo: 10.129.2.37

Dominio identificado: blog.inlanefreight.local

Contexto: Skills Assessment del módulo "Hacking WordPress" de Hack The Box Academy

1. Resumen Ejecutivo
2. Alcance y Metodología
3. Fase de Reconocimiento
 - 3.1 Configuración inicial
 - 3.2 Enumeración de versión WordPress
 - 3.3 Enumeración del tema
 - 3.4 Enumeración de usuarios
 - 3.5 Enumeración de plugins vulnerables
 - 3.6 Enumeración de directorios
4. Fase de Explotación
 - 4.1 Flag 1 - Versión WordPress
 - 4.2 Flag 2 - Tema en uso
 - 4.3 Flag 3 - Directory listing
 - 4.4 Flag 4 - Usuario no administrador
 - 4.5 Flag 5 - Descarga no autenticada
 - 4.6 Flag 6 - Plugin vulnerable a LFI
 - 4.7 Flag 7 - Usuario del sistema
 - 4.8 Obtención de hashes con Metasploit
 - 4.9 Fuerza bruta a la cuenta erika
 - 4.10 Webshell y flag final
5. Errores documentados y soluciones
6. Conclusión y recomendaciones
7. Anexo técnico

1. Resumen Ejecutivo

Se realizó una auditoría de seguridad ofensiva contra la infraestructura WordPress perteneciente a INLANEFREIGHT. El objetivo de la evaluación fue identificar vulnerabilidades explotables desde una perspectiva externa sin credenciales iniciales. Durante el ejercicio se detectaron múltiples fallos críticos de seguridad relacionados con versiones obsoletas de WordPress, plugins vulnerables, configuraciones inseguras del servidor web y debilidades graves en las políticas de autenticación. La combinación de vulnerabilidades permitió a un atacante no autenticado:

- Enumerar información sensible del entorno
- Descargar datos sin autenticación
- Leer archivos internos del servidor
- Obtener hashes de contraseñas WordPress
- Comprometer cuentas válidas mediante fuerza bruta
- Subir una webshell PHP
- Ejecutar comandos arbitrarios en el servidor objetivo

El impacto global de la intrusión se clasifica como CRÍTICO.

2. Alcance y Metodología

El alcance de la auditoría se limitó exclusivamente al host 10.129.2.37 y a la aplicación WordPress identificada en el subdominio blog.inlanefreight.local. La metodología utilizada siguió un enfoque clásico de pentesting:

1. Reconocimiento pasivo y activo
2. Enumeración de tecnologías y componentes
3. Identificación de superficie de ataque
4. Explotación controlada
5. Obtención de acceso privilegiado
6. Validación de impacto
7. Documentación técnica

Herramientas utilizadas:

- curl
- WPScan
- Metasploit Framework
- John The Ripper
- Hashcat
- Gobuster
- Netcat
- Firefox / Chrome
- XML-RPC requests

3.1 Configuración inicial

Inicialmente se realizó una petición HTTP contra la IP objetivo mediante curl. El contenido devuelto correspondía a un portal corporativo estático denominado “Inlane Freight”. No se observaron indicadores directos de WordPress en la raíz del sitio. Sin embargo, mediante inspección del código fuente HTML se identificó un enlace al subdominio blog.inlanefreight.local. Dado que el dominio no resolvía mediante DNS público, fue necesario añadir una entrada manual al archivo /etc/hosts. Tras esta modificación fue posible acceder correctamente a la aplicación WordPress.

3.2 Enumeración de versión WordPress

La enumeración de la versión de WordPress se realizó utilizando múltiples técnicas para validar resultados. La primera técnica consistió en revisar el meta tag “generator” presente en el código fuente HTML principal. Posteriormente se validó la misma versión mediante el feed RSS. La versión identificada fue WordPress 5.1.6, considerada obsoleta y vulnerable a múltiples CVEs públicas. WPScan identificó más de 40 vulnerabilidades asociadas a esta versión.

3.3 Enumeración del tema

Se identificó el tema activo “twentyineteen” versión 1.3. La enumeración se realizó mediante WPScan y validación manual consultando el archivo style.css del tema. Aunque el tema no

representó el vector principal de compromiso, su identificación permitió confirmar la estructura de directorios WordPress y preparar posteriores intentos de modificación de código PHP.

3.4 Enumeración de usuarios

La enumeración de usuarios se realizó utilizando el parámetro author de WordPress y posteriormente mediante WPScan. Usuarios identificados: • admin • erika • Charlie Wiggins La enumeración de usuarios facilitó posteriormente la ejecución de ataques de fuerza bruta y validación de credenciales.

3.5 Enumeración de plugins vulnerables

WPScan identificó múltiples plugins vulnerables instalados en el entorno. Plugins críticos: • email-subscribers 4.2.2 • site-editor 1.1.1 • the-events-calendar 5.1.2.1 El plugin Email Subscribers contenía múltiples vulnerabilidades críticas incluyendo SQL Injection sin autenticación y descarga arbitraria de información. El plugin Site Editor presentaba una vulnerabilidad Local File Inclusion (LFI) explotable. La presencia simultánea de múltiples plugins desactualizados aumentó significativamente la superficie de ataque.

3.6 Enumeración de directorios

El directorio /wp-content/uploads/ tenía habilitado el directory listing, permitiendo visualizar archivos internos directamente desde el navegador. Esto constituye una mala práctica crítica de hardening ya que expone información sensible a usuarios no autenticados. Dentro del directorio se identificó el archivo upload_flag.txt que contenía una de las flags del laboratorio.

4. Fase de Explotación

La explotación comenzó utilizando vulnerabilidades conocidas del plugin Email Subscribers. Posteriormente se explotó el Local File Inclusion del plugin Site Editor. El acceso a hashes WordPress permitió realizar ataques de cracking y fuerza bruta sobre cuentas válidas. Finalmente se obtuvo acceso administrativo al panel WordPress mediante las credenciales comprometidas de erika. Con privilegios suficientes se subió un plugin malicioso que proporcionó ejecución remota de comandos como www-data.

4.5 Descarga no autenticada - CVE-2019-19985

La vulnerabilidad CVE-2019-19985 permitió descargar información sensible sin necesidad de autenticación. La explotación se realizó mediante una petición HTTP directa contra: /wp-admin/admin.php?page=download_report&report;=users&status;=all La respuesta devolvió datos de usuarios y la flag HTB{unauTh_d0wn10ad!}. Esta vulnerabilidad representa una fuga crítica de información y demuestra falta de controles de autorización.

4.6 Local File Inclusion

El plugin Site Editor versión 1.1.1 era vulnerable a Local File Inclusion. La explotación permitió acceder al archivo `/etc/passwd` y enumerar usuarios del sistema operativo Linux subyacente. La lectura de archivos locales constituye una vulnerabilidad crítica ya que puede facilitar robo de credenciales, divulgación de configuraciones y preparación de ataques posteriores.

4.8 Obtención de hashes con Metasploit

Se utilizó el módulo `auxiliary/scanner/http/wp_email_sub_news_sqli` de Metasploit para extraer hashes WordPress. Hashes obtenidos: • admin • erika • charlie Los hashes estaban protegidos mediante `phpass`.

4.9 Fuerza bruta a la cuenta erika

Inicialmente se intentó crackear el hash utilizando `rockyou.txt` sin éxito. Posteriormente se utilizó una wordlist numérica personalizada de 6 dígitos mediante el mecanismo XML-RPC de WordPress. La contraseña comprometida fue: erika : 010203 La contraseña era extremadamente débil y no cumplía políticas mínimas de seguridad.

4.10 Webshell y flag final

Con acceso autenticado al panel WordPress se intentó modificar directamente el tema activo. Sin embargo, WordPress bloqueó la modificación PHP debido a mecanismos de validación interna. Como alternativa se desarrolló un plugin PHP malicioso con una webshell basada en `system($_GET["cmd"])`. Tras subir y activar el plugin se obtuvo ejecución remota de comandos con permisos `www-data`. Finalmente se accedió al directorio `/home/erika/` y se obtuvo la flag final: `HTB{w0rdPr355_4SS3ssm3n7}`

5. Errores documentados y soluciones

Durante el proceso se documentaron diversos problemas técnicos y operativos: • Falta de resolución DNS del subdominio • Configuración incorrecta de VHOST en Metasploit • Wordlists insuficientes para cracking • Restricciones PHP del editor WordPress • Problemas de rutas de plugins • Errores de formato en Hashcat Cada problema fue solucionado mediante ajustes manuales, validación de configuraciones y adaptación de técnicas.

6. Conclusión y recomendaciones

La auditoría demuestra que el entorno WordPress evaluado presenta una postura de seguridad crítica. Las vulnerabilidades identificadas permitieron compromiso total del servidor desde una perspectiva no autenticada. Recomendaciones inmediatas: • Actualizar WordPress a la última

versión estable • Eliminar plugins vulnerables • Deshabilitar directory listing • Implementar MFA / 2FA

- Aplicar políticas robustas de contraseñas
- Limitar intentos de autenticación
- Implementar monitorización continua
- Desplegar un WAF
- Realizar auditorías periódicas

Nivel de riesgo: CRÍTICO

Evidencias Técnicas

```
curl -s http://blog.inlanefreight.local/ | grep generator

<meta name="generator" content="WordPress 5.1.6" />

wpscan --url http://blog.inlanefreight.local -e u

curl 'http://blog.inlanefreight.local/wp-admin/admin.php?page=download_report&report=users&status=all'

curl -s "http://blog.inlanefreight.local/wp-content/plugins/site-editor/editor/extensions/pagebuilder/"

msfconsole
use auxiliary/scanner/http/wp_email_sub_news_sqli

wpscan --url http://blog.inlanefreight.local --password-attack xmlrpc -U erika -P /tmp/numeric.txt

[SUCCESS] - erika / 010203

curl -s "http://blog.inlanefreight.local/wp-content/plugins/shell/shell.php?cmd=id"

uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

7. Anexo - Flags obtenidas

Pregunta	Flag
1	5.1.6
2	twentynineteen
3	HTB{d1sabI3_d1r3ct0ry_l1st1ng!}
4	Charlie Wiggins
5	HTB{unauTh_d0wn10ad!}
6	1.1.1
7	frank.mclane
8	HTB{w0rdPr355_4SS3ssm3n7}

FIN DEL INFORME